

SEMINÁRIO · TÓPICOS AVANÇADOS EM CIÊNCIA DA COMPUTAÇÃO

# Roteiro de Apresentação

## Revisão de Cibersegurança, Normas e Padrões

Falas sugeridas, interações com a turma e ações na tela, slide a slide, para cada integrante da equipe.

**Arthur Oliveira Santos**

Bloco 1 · Fundamentos · TO/ICS

**Gabriela Lacerda Muniz**

Bloco 2 · Frameworks · Notícias

**Diego Pereira Maia**

Bloco 3 · Privacidade · Artigos

**Vinícius Goddart**

Bloco 4 · IA · Questões

41 slides · duração planejada de cerca de 109 minutos (mínimo exigido: 80). As falas são sugestões: usem as próprias palavras, mas mantenham as ideias centrais e as interações.

## Divisão de responsabilidades

| INTEGRANTE | SLIDES EM QUE FALA                                                                                                              | TEMPO APROX. |
|------------|---------------------------------------------------------------------------------------------------------------------------------|--------------|
| Arthur     | 1–2 (abertura), 3–8 (Bloco 1), 26–27 (tópico adicional: TO/ICS), 31 (Questão 1), 37 (conduz a síntese), 41 (abre e fecha o Q&A) | ~33 min      |
| Gabriela   | 9–14 (Bloco 2), 28 (Notícias), 33 (Questão 3), 38 (Checklist)                                                                   | ~25 min      |
| Diego      | 15–20 (Bloco 3), 29 (Artigos), 34 (Questão 4), 39 (conduz a votação da Mesa de Crise)                                           | ~25 min      |
| Vinícius   | 21–25 (Bloco 4), 30 (regras das questões), 32 (Questão 2), 35 (Questão 5), 36 (Bônus), 39 (narra a Mesa de Crise)               | ~26 min      |

Tempos por bloco: Abertura + Bloco 1 ≈ 22 min · Bloco 2 ≈ 17,5 · Bloco 3 ≈ 15,5 · Bloco 4 ≈ 12,5 · Complementos ≈ 11 · Questões ≈ 17,5 · Encerramento ≈ 13.

O slide **40 (Referências)** é de consulta e não está distribuído: qualquer integrante o exibe por alguns segundos antes do Q&A.

## Como operar a apresentação

### Atalhos

- ou Espaço: próximo · ←: anterior
- G: ir para um slide (digite o número e Enter)
- N: notas do apresentador (tempo de cada slide)
- O: visão geral · F: tela cheia
- T: inicia/pausa o cronômetro da questão
- H: ajuda, chance da imagem surpresa e botão de teste

### Dinâmica

- Quem está falando também passa os slides. Na troca de bloco, a próxima pessoa assume o teclado.
- O cronômetro geral fica na barra inferior: iniciem no slide 1.
- Se aparecer a **imagem surpresa**, reajam com leveza ("o sistema foi invadido!") e apertem Continuar.
- Se recarregar a página, a apresentação volta no mesmo slide.

### Checklist antes de começar

- Testar o projetor e a internet (os ícones, as fontes e o estilo vêm da internet).
- Abrir **H** → **Limpar dados salvos** para zerar checklists, cronômetro e posição.
- Atualizar o slide 28 com uma notícia da semana e conferir o status do PL 2338/2023 e do AI Act.
- Conferir o slide 40 (Referências): se trocarem alguma notícia ou questão, a fonte precisa entrar lá.
- Colocar as imagens da surpresa em **images/** e rodar **images/atualizar-manifest.ps1**.
- Combinar como a turma vai votar nas questões (mão levantada ou duas equipes com placar no quadro).

# Abertura

## 1 Capa

Arthur (todos se apresentam) • ~1,5 min

### FALA

"Boa noite a todos. Nós somos Arthur, Gabriela, Diego e Vinícius, e hoje vamos fazer uma revisão de Cibersegurança, Normas e Padrões. A ideia é partir dos fundamentos que vocês já viram, como a Tríade CIA, e chegar até o que está mais em alta hoje: regulação de privacidade e de inteligência artificial."

"Uma frase guia a apresentação: segurança não é um produto, é um processo. E hoje esse processo é cobrado por lei, por contrato e, cada vez mais, por regras específicas para IA."

### INTERAÇÃO

- Cada integrante fala o próprio nome e o bloco que vai apresentar.
- Iniciar o cronômetro geral na barra inferior.
- Avisar que haverá interatividade em quase todos os slides, questões com cronômetro e uma simulação de crise no fim.

## 2 Agenda e objetivos

Arthur • ~2,5 min

"Vamos em sete etapas. Eu abro com os fundamentos. A Gabriela mostra como as normas e frameworks organizam a segurança. O Diego entra em privacidade e LGPD. O Vinícius fecha a parte teórica com regulação e segurança de IA."

"Depois temos um tópico extra, segurança de sistemas industriais, notícias recentes, três artigos que mostram a evolução da área, seis questões no estilo do ENADE e do Cebraspe, e uma simulação de crise em que vocês decidem."

"Ao final, queremos que vocês consigam explicar a CIA expandida, diferenciar norma de framework e de lei, aplicar as bases legais da LGPD, classificar sistemas de IA por risco e, principalmente, perceber que estar em compliance não é o mesmo que estar seguro."

Transição: "Vamos começar pelo mapa da disciplina."

### 3 Resumo da disciplina

Arthur · ~3 min

"Este é o resumo da disciplina. Ela se organiza em seis eixos: fundamentos, criptografia, redes e sistemas, segurança de software, governança e normas, e privacidade e direito."

"O que une tudo é a gestão de risco. Risco é probabilidade vezes impacto. A probabilidade depende de haver uma ameaça e uma vulnerabilidade que ela consiga explorar. Todo controle de segurança existe para reduzir um desses fatores."

#### INTERAÇÃO

- Perguntar: *"Um notebook sem criptografia de disco esquecido num táxi: qual a probabilidade? Qual o impacto?"*
- Clicar na célula que a turma escolher na matriz (por exemplo, probabilidade 3 × impacto 4 = 12, Alto).
- Mostrar as quatro estratégias de tratamento: mitigar (criptografar o disco), transferir (seguro), evitar (proibir dados no notebook), aceitar.

### 4 Tríade CIA expandida

Arthur · ~3 min

"A base de tudo é a CIA: Confidencialidade, Integridade e Disponibilidade. Hoje ela costuma ser expandida com Autenticidade e Não-repúdio."

"Confidencialidade é só quem pode ver, ver. Integridade é o dado não ser alterado sem que se perceba. Disponibilidade é o serviço estar lá quando precisamos. Autenticidade é ter certeza de quem é a origem. Não-repúdio é o autor não conseguir negar que fez."

"Esses pilares entram em tensão: criptografia forte aumenta a confidencialidade, mas se a chave se perde, perdemos a disponibilidade."

#### INTERAÇÃO

- Clicar em cada pilar. Antes de mostrar a coluna "Controles", perguntar: *"que controle vocês usariam?"*
- Fazer o mini-jogo "Qual pilar foi violado?" com a turma respondendo em voz alta.
- Respostas: botnet derrubando o site → D · atendente lendo prontuário → C · malware trocando o boleto → I · login compartilhado → Não-repúdio.
- Ler a frase do rodapé: assinatura digital não garante confidencialidade. Ela volta nas Questões 1 e 2.

## 5 Cenário atual de ameaças

Arthur · ~3 min

"O adversário hoje é profissional. Existe uma cadeia de valor no crime cibernético, com divisão de trabalho, e isso barateou os ataques."

"O spear phishing é o phishing direcionado, feito depois de pesquisar a vítima. O ransomware virou serviço: um grupo desenvolve, outro vende acessos, afiliados invadem e dividem o lucro. Na cadeia de suprimentos, o invasor compromete um fornecedor e chega a milhares de vítimas pelo canal legítimo de atualização. E o zero-day é a falha que ainda não tem correção."

### INTERAÇÃO

- Passar pelas quatro abas e, em cada uma, terminar pelo cartão de **incidente real** no rodapé (Arup, Change Healthcare, Kaseya, Ivanti).
- Usar a coluna da esquerda, **Cyber Kill Chain x MITRE ATT&CK**, para situar cada aba: phishing e zero-day estão em *Entrega/Exploração*; o ransomware só aparece em *Ações no objetivo*, quando já é tarde.
- Diferença a destacar: a Kill Chain é **linear** e boa para narrar o ataque; o ATT&CK é uma **matriz** de táticas e técnicas, usada para medir cobertura de detecção — cada técnica vira uma regra no SIEM.
- Na aba Cadeia de suprimentos, contar o caso XZ Utils: um "mantenedor" ganhou a confiança do projeto por quase dois anos e inseriu um backdoor. Foi descoberto por acaso, por uma lentidão de meio segundo no SSH.
- Perguntar: "*alguém já recebeu um golpe no WhatsApp se passando por um parente?*" — é engenharia social dirigida. Em Arup e Change Healthcare, o invasor não quebrou criptografia nenhuma: explorou processo e ausência de MFA.

## 6 Defesa em profundidade e menor privilégio

Arthur · ~2,5 min

"Dois princípios de arquitetura. Defesa em profundidade: como um castelo medieval, com fosso, muralha, portão e guarda. Nenhuma camada é perfeita, mas juntas elas atrasam, detectam e contêm o atacante."

"Menor privilégio: cada usuário ou serviço recebe só as permissões de que precisa, e só pelo tempo necessário. Isso diminui o "raio de explosão" quando uma credencial vaza."

### INTERAÇÃO

- Clicar nas camadas de fora para dentro, de Políticas & Pessoas até Dados.
- No exemplo de IAM, perguntar: "*se a chave desse serviço vazar, o que o atacante consegue fazer em cada versão?*"
- Resposta: na primeira, tudo no S3 da conta; na segunda, só ler relatórios de 2026, e somente por HTTPS.

## 7 Arquitetura Zero Trust

Arthur · ~3,5 min

"Zero Trust parte de "nunca confiar, sempre verificar". Estar dentro da rede da empresa não dá confiança nenhuma. Cada acesso é decidido na hora, olhando identidade, dispositivo e contexto."

"Pela NIST SP 800-207, quem decide é o PDP, o ponto de decisão de política, e quem aplica é o PEP, o ponto de aplicação. Somam-se microsegmentação, para impedir que o invasor se mova lateralmente, e a premissa de assumir que a violação já aconteceu."

### INTERAÇÃO — SIMULADOR

- 1) Deixe FIDO2 + gerenciado + casa + normal + CRM → PERMITIR.
- 2) Troque "Casa" por "Rede corporativa" e mostre que a pontuação **não muda**: a rede não gera confiança.
- 3) Selecione "Só senha" → STEP-UP (pede verificação adicional).
- 4) Volte o FIDO2, selecione "Download em massa" + "Base de clientes (PII)" → NEGAR + alerta ao SOC.
- Peça para a turma sugerir a próxima combinação.

## 8 Estudo de caso: Colonial Pipeline

Arthur · ~3 min

"Para juntar tudo, um caso real. Em 2021, a Colonial Pipeline, que transporta cerca de 45% do combustível da Costa Leste dos EUA, sofreu um ransomware do grupo DarkSide."

"A entrada foi no dia 29 de abril, numa conta de VPN antiga, que ninguém usava, com uma senha que tinha vazado e sem MFA. No dia 6 de maio saíram cerca de 100 GB de dados. Na madrugada do dia 7 veio a criptografia, e por volta das seis da manhã a empresa parou os dutos — uma decisão de negócio, não técnica: eles não conseguiam faturar e não tinham certeza se a rede industrial também estava comprometida."

"No mesmo dia pagaram cerca de 4,4 milhões de dólares em bitcoin, mas o decryptor era tão lento que acabaram restaurando dos próprios backups. Dia 9 o governo americano declarou emergência em 17 estados; dia 12 os dutos voltaram; em junho o FBI recuperou 85% do resgate. E o caso gerou regulação: a Ordem Executiva 14028 e as diretivas de segurança da TSA para dutos."

### INTERAÇÃO

- Percorrer a linha do tempo à esquerda destacando o intervalo: **oito dias** entre o acesso inicial e o desligamento.
- Perguntar, antes de virar cada cartão: *"qual princípio falhou aqui?"*
- Autenticidade (senha sem MFA) · Menor privilégio (conta inativa não desativada) · Zero Trust (VPN dava confiança implícita) · Defesa em profundidade (sem segmentação confiável entre TI e TO, a saída foi parar tudo).

Transição: "Controles técnicos isolados não bastam: é preciso governança. Gabriela, com você."

## Bloco 2 · Regulações e Frameworks — Gabriela

### 9 Por que governança?

Gabriela · ~2 min

"Segurança sem método não escala. Normas e frameworks dão uma linguagem comum para TI, jurídico e diretoria, uma referência do que é suficiente e evidências para auditores, clientes e reguladores."

"Tem uma diferença importante de obrigatoriedade. O NIST CSF é um framework voluntário. A ISO 27001 também é voluntária, mas é certificável. O PCI DSS é imposto por contrato pelas bandeiras de cartão. E a LGPD e a Resolução 4.893 do CMN têm força de lei ou de norma de regulador."

#### INTERAÇÃO

- Perguntar: "uma startup é obrigada por lei a ter ISO 27001?" Não, mas um cliente grande pode exigir em contrato.
- Mini-jogo "Qual referência resolve o problema?":
- Loja que guarda cartão → PCI · banco digital contratando nuvem → 4.893 · SaaS que quer provar segurança a clientes → ISO · prefeitura medindo maturidade → CSF.

## 10 ISO/IEC 27001 e 27002

Gabriela · ~3,5 min

"A ISO 27001 tem duas metades. A primeira é o SGSI, o Sistema de Gestão da Segurança da Informação: são as cláusulas 4 a 10, que seguem o ciclo PDCA. Contexto, liderança, planejamento e apoio são o Planejar; a cláusula 8, Operação, é o Executar; a 9, com auditoria interna e análise crítica, é o Verificar; e a 10, melhoria, é o Agir. É essa metade que se certifica."

"A segunda metade é o Anexo A: 93 controles organizados em quatro temas. **Organizacionais**, com 37 controles, são as regras de gestão — políticas, normas, procedimentos, papéis, gestão de ativos e de fornecedores. **Pessoas**, com 8, tratam do comportamento: seleção, treinamento, o que acontece quando alguém sai. **Físicos**, com 14, protegem instalações, equipamentos e mídias. E **Tecnológicos**, com 34, são os controles dentro dos sistemas."

"A ligação entre as duas metades é o risco: um controle do Anexo A não entra porque está na lista, entra porque a avaliação de riscos pediu — e a Declaração de Aplicabilidade justifica cada inclusão ou exclusão. A 27002 é o guia de como implementar esses controles, e não é certificável."

### INTERAÇÃO

- Apresentar primeiro a coluna da direita (o SGSI e o PDCA) e só depois clicar nos quatro temas da esquerda.
- Perguntar antes de mostrar os números: "qual tema vocês acham que tem mais controles?" A maioria chuta Tecnológicos, mas são os Organizacionais: 37 contra 34. E só 8 são de Pessoas, embora quase todo incidente comece por uma pessoa.
- No tema Pessoas, ligar o controle 6.5 ao Colonial Pipeline: a conta de quem já tinha saído continuava ativa.
- Pegadinha de prova: a versão 2013 tinha 114 controles em 14 domínios. Muita apostila ainda traz esse número.
- Dica: guardem que "controlar mudanças" é Operação, não Liderança — isso cai na Questão 3.

## 11 NIST CSF 2.0

Gabriela · ~3,5 min

"O NIST Cybersecurity Framework 2.0 saiu em fevereiro de 2024. Ele organiza a segurança em seis funções: Governar, Identificar, Proteger, Detectar, Responder e Recuperar."

"A grande novidade é a função Governar, no centro. Ela tira a segurança do nível só técnico e a coloca na estratégia da empresa, incluindo o risco da cadeia de suprimentos. O framework usa perfis — o atual e o alvo — e a diferença entre eles vira o plano de ação."

### INTERAÇÃO

- Clicar em Governar e depois nas outras funções, no sentido horário.
- Perguntar: "o que vocês acham que é mais negligenciado nas empresas: detectar ou recuperar?" — estimular o debate; muitas nunca testam a recuperação.

## 12 PCI DSS v4 e Res. CMN 4.893

Gabriela · ~3 min

"Dois padrões setoriais. O PCI DSS vale para quem armazena, processa ou transmite dados de cartão. Tem 12 requisitos. A versão 4 exigiu MFA para todo acesso ao ambiente de cartão, senhas de 12 caracteres e o monitoramento dos scripts da página de pagamento, contra ataques que roubam o cartão direto no checkout."

"A Resolução 4.893 do CMN vale para as instituições autorizadas pelo Banco Central. Ela exige política de segurança cibernética aprovada pela diretoria, um diretor responsável, plano de resposta a incidentes, comunicação de incidentes relevantes ao BC e regras para contratar nuvem."

### INTERAÇÃO

- Perguntar: "se o banco terceiriza o serviço e o fornecedor é invadido, quem responde ao Banco Central?"  
A instituição continua responsável.

## 13 Gestão e resposta a incidentes

Gabriela · ~3 min

"Quando o incidente acontece, a referência é a NIST SP 800-61: preparação, detecção e análise, contenção, erradicação, recuperação e lições aprendidas."

"E o relógio regulatório começa a correr. Pela LGPD e pela Resolução 15 da ANPD, de 2024, é preciso comunicar a ANPD e os titulares em até três dias úteis. No GDPR são 72 horas. Os prazos correm em paralelo: uma fintech pode ter ANPD, Banco Central e GDPR ao mesmo tempo."

### INTERAÇÃO

- Clicar nas seis fases.
- Na Contenção, perguntar: "desligar tudo é uma boa ideia?" Nem sempre: destrói evidências na memória e para o negócio. Isso volta na Mesa de Crise.

## 14 Conformidade vs. segurança real

Gabriela · ~2,5 min

"Estar em compliance não é estar seguro. A Target, em 2013, tinha certificação PCI meses antes de vazar cerca de 40 milhões de cartões. O invasor entrou pelas credenciais de um fornecedor de climatização, e os alertas foram ignorados."

"Compliance é o piso, não o teto. A auditoria é uma foto; o ataque é um filme."

### INTERAÇÃO

- Fazer a turma votar em cada cenário antes de clicar.
- A (senha trocada todo mês que vira Empresa@01) → conforme, inseguro · B (startup com EDR e sem DPO) → seguro, não conforme · C (pentest com falhas abertas) → conforme, inseguro · D (controles medidos e testados) → conforme e seguro.

Transição: "Até aqui protegemos o ativo. Agora vamos falar dos direitos das pessoas sobre os dados. Diego."

## Bloco 3 · Privacidade e Proteção de Dados — Diego

### 15 Segurança × privacidade

Diego · ~1,5 min

"Segurança da informação protege qualquer informação e pergunta: "o dado está protegido?". Privacidade trata de dados pessoais e pergunta: "podemos usar esse dado, e para quê?"."

"A relação é assimétrica. Dá para ter segurança sem privacidade — um banco de dados perfeitamente criptografado com dados coletados sem base legal. Mas não existe privacidade sem segurança: a LGPD, no artigo 46, exige medidas técnicas para proteger os dados."

#### INTERAÇÃO

- Abrir com a pergunta do cartão: *"um sistema que vende relatórios de localização de clientes, com criptografia de ponta, é seguro? E é lícito?"*
- Pode ser seguro e ainda assim ilícito: sem base legal, com finalidade incompatível e sem transparência.

### 16 LGPD × GDPR

Diego · ~3 min

"A LGPD foi inspirada no GDPR europeu, mas elas são irmãs, não gêmeas. A LGPD tem 10 bases legais e o GDPR tem 6. A multa da LGPD é de até 2% do faturamento no Brasil, limitada a 50 milhões de reais por infração; no GDPR chega a 4% do faturamento global. O prazo de notificação de incidente é de 3 dias úteis aqui e de 72 horas lá."

"E os princípios guiam tudo: finalidade, adequação, necessidade, livre acesso, transparência, qualidade dos dados, entre outros."

#### INTERAÇÃO

- Para cada princípio, pedir um exemplo à turma e depois virar o cartão.
- Exemplo de adequação: um app de lanterna pedindo acesso aos contatos.

## 17 Bases legais

Diego · ~3 min

"Sem base legal não há tratamento. E existe um mito: "sempre precisa de consentimento". O consentimento é só uma das dez bases, e muitas vezes a mais frágil, porque o titular pode revogar a qualquer momento."

"O legítimo interesse exige um teste documentado, o LIA: finalidade legítima, necessidade e balanceamento com os direitos do titular. E para dados sensíveis, como saúde e biometria, o legítimo interesse não vale."

"A base mais usada no dia a dia, e a menos lembrada, é a **execução de contrato**, do inciso V: o tratamento necessário para entregar o que o titular contratou — cadastro, cobrança, entrega — e também os procedimentos preliminares, como um orçamento pedido por ele. O limite é o necessário: usar o mesmo endereço para marketing já exige outra base. E o titular precisa ser parte do contrato; contrato entre terceiros não serve."

### INTERAÇÃO

- Fazer o mini-jogo com a turma votando.
- Banco comunicando ao COAF → obrigação legal · endereço para entrega → contrato · e-mail compartilhado com parceiros → consentimento · análise de logs contra fraude → legítimo interesse.

## 18 Direitos dos titulares

Diego · ~2,5 min

"O titular pode pedir confirmação e acesso, correção, eliminação, portabilidade, revogação do consentimento e revisão de decisões automatizadas."

"Atender isso é um problema de engenharia. O fluxo é: o canal recebe, autentica o titular, localiza os dados, responde no prazo e registra. Sem inventário de dados, a empresa não consegue responder em 15 dias."

### INTERAÇÃO

- Mostrar o fluxo de cinco passos e depois abrir "Confirmação e acesso". Cada direito tem três partes: o que o titular pode exigir, o que isso exige de engenharia e a **armadilha** em vermelho.
- Perguntar: "por que autenticar quem pede os dados?" Porque um golpista pode se passar pelo titular para roubar o dossiê dele — e aí o próprio atendimento vira o incidente.
- Abrir também "Eliminação" (o que fica retido por obrigação legal) e fechar em "Revisão de decisão automatizada", que já prepara o Bloco 4.
- Usar o cartão do rodapé — pedido típico e resposta adequada — como exemplo concreto de cada direito.

## 19 Controlador, operador e encarregado

Diego · ~2,5 min

"O controlador decide: define a finalidade e os meios. O operador executa em nome do controlador e responde junto se descumprir a lei ou as instruções. O encarregado, ou DPO, é a ponte com os titulares e com a ANPD."

"O papel é definido pelo que a empresa faz, não pelo que o contrato diz."

### INTERAÇÃO

- Fazer o mini-jogo. Deixar o cenário 4 por último.
- SaaS de folha → operador · hospital → controlador · quem responde à ANPD → encarregado · nuvem que treina a própria IA com dados dos clientes → controlador, porque passou a definir uma finalidade própria.

## 20 ANPD e RIPD

Diego · ~2,5 min

"A ANPD regula, orienta, fiscaliza e sanciona. As sanções vão de advertência e multa até a proibição da atividade de tratamento. Em 2024, por exemplo, ela suspendeu cautelarmente o uso de dados de brasileiros para treinar a IA da Meta."

"O principal instrumento de gestão é o RIPD, o Relatório de Impacto à Proteção de Dados, equivalente ao DPIA europeu. Ele é feito para tratamentos de alto risco e é um documento vivo."

### INTERAÇÃO

- Marcar os passos do checklist do RIPD com a turma, um a um.
- Destacar o passo 4: os riscos são avaliados **para os titulares**, não só para a empresa.

---

Transição: "E quando quem trata os dados é um modelo de IA? Vinícius."

## Bloco 4 · Regulação e Segurança em IA — Vinícius

### 21 O novo vetor da IA

Vinícius · ~1 min

"A IA é ao mesmo tempo ferramenta de defesa, arma e alvo. Defende quando faz triagem de alertas no SOC; ataca quando gera phishing perfeito e deepfakes; e é alvo de ataques próprios."

"A frase-chave do bloco é: num LLM, dados viram instruções. É daí que vem a prompt injection, e é por isso que a segurança clássica não resolve tudo."

### 22 EU AI Act

Vinícius · ~3 min

"O AI Act europeu, de 2024, regula por nível de risco. No topo, o risco inaceitável é proibido: pontuação social, reconhecimento de emoções no trabalho e na escola. Alto risco é permitido com obrigações pesadas: recrutamento, crédito, educação. Risco limitado exige transparência, como avisar que é um chatbot. E risco mínimo, como filtro de spam, não tem obrigações específicas."

"O ponto importante: ele regula o uso, não a tecnologia. O mesmo modelo pode ser mínimo num jogo e alto risco no RH. As multas chegam a 35 milhões de euros ou 7% do faturamento global."

#### INTERAÇÃO

- Clicar na pirâmide de cima para baixo.
- Mini-jogo: triagem de currículos → alto · chatbot de loja → limitado · câmeras medindo emoção de alunos → inaceitável.
- Citar que a proposta "Digital Omnibus" pode adiar parte das regras de alto risco (verificar o status na semana).

### 23 PL 2338/2023

Vinícius · ~2,5 min

"No Brasil, o PL 2338 de 2023 foi aprovado pelo Senado em dezembro de 2024 e está na Câmara. A lógica é parecida com a europeia, com risco excessivo e alto risco, mas com mais ênfase nos direitos das pessoas afetadas: saber que está falando com uma IA, pedir explicação, contestar a decisão e ter revisão humana."

"Um exemplo de discriminação algorítmica: um modelo de crédito que usa o CEP pode reproduzir desigualdades raciais e regionais, mesmo sem usar raça como variável. Isso é discriminação indireta."

#### INTERAÇÃO

- Perguntar: "que outra variável 'neutra' pode funcionar como substituta de raça ou gênero?" Nome, escola, bairro, horário de uso do app.

## 24 Segurança técnica em IA

Vinícius • ~3,5 min

"Três ataques principais. Prompt injection: direta, quando o próprio usuário tenta enganar o modelo, ou indireta, quando a instrução maliciosa está escondida num documento ou página que o modelo lê. Data poisoning: envenenar os dados de treino para criar backdoors. E exfiltração: o assistente com RAG entregar documentos que o usuário não poderia ver."

"Não existe filtro 100% eficaz. A defesa realista é limitar o impacto."

### INTERAÇÃO — DEMO

- 1ª execução sem nenhuma defesa → o agente envia a planilha de salários para fora.
- 2ª execução só com o "Classificador de injeção" → na maioria das vezes bloqueia, mas às vezes uma variante ofuscada passa. Rodar duas ou três vezes para mostrar.
- 3ª execução com "Menor privilégio" e "Aprovação humana" → bloqueado mesmo quando o modelo é enganado.
- Mensagem: defesa em profundidade também vale para IA. (A demo é uma simulação, não um LLM real.)

## 25 AI TRiSM

Vinícius • ~2 min

"AI TRiSM é um termo da Gartner para Trust, Risk and Security Management: explicabilidade e monitoramento, ModelOps, segurança das aplicações de IA e privacidade."

"Como referência há o NIST AI RMF e a ISO/IEC 42001, que é a "27001 da IA", com a mesma lógica PDCA. O ciclo de vida seguro vai dos dados até a desativação do modelo, e a auditoria precisa ser contínua."

### INTERAÇÃO

- Clicar nas etapas do ciclo de vida, destacando **Avaliação** (quase ninguém faz red team antes de produção) e **Desativação** (o endpoint velho que continua no ar).
- Insistir na terceira caixa de cada etapa, a **evidência**: é o que separa governança de intenção. Se a etapa não gera artefato automaticamente, ela não é auditável.
- Se perguntarem por onde começar: inventário dos sistemas de IA e classificação de risco — é o primeiro item do checklist do slide 38.

Transição: "Agora os complementos. Arthur traz o tópico adicional."

### 26 Tópico adicional: por que TO/ICS é outro jogo

Arthur · ~2 min

"Escolhemos este tópico porque a disciplina toda fala de sistemas de informação, e existe um mundo ao lado em que a mesma falha deixa de ser um vazamento e vira um acidente físico: a tecnologia operacional, que controla fábricas, subestações e dutos. É a continuação natural do caso Colonial Pipeline."

"A primeira coisa que muda é a ordem da tríade. Em TI é confidencialidade, integridade e disponibilidade. Em TO vem primeiro a segurança física das pessoas, depois a disponibilidade: parar uma planta pode ser pior que o próprio ataque. Depois, o contexto: equipamentos com ciclo de vida de vinte, trinta anos; sem janela de manutenção para aplicar patch; protocolos como Modbus e DNP3 que nasceram sem autenticação, porque se presumia uma rede isolada; e um PLC não roda agente de EDR. A defesa precisa vir da arquitetura."

"E é uma área com história própria. Em 2010 o Stuxnet mostrou que dava para destruir equipamento físico com software. Em 2015 e 2016, na Ucrânia, o invasor abriu disjuntores na frente do operador e depois veio o primeiro malware que falava os protocolos elétricos sozinho. Em 2017 o TRITON atacou o sistema instrumentado de segurança de uma petroquímica, ou seja, a última barreira antes de uma explosão. E em 2022 isso virou ferramenta modular, que funciona em PLCs de vários fabricantes."

#### INTERAÇÃO

- Nos incidentes, o arco é o que importa: em 2010 era uma operação de Estado feita sob medida; em 2022 já são ferramentas modulares que funcionam em PLCs de vários fabricantes.
- Fechar no **TRITON**, que é o mais grave conceitualmente: atacar o SIS é desligar a última barreira antes do acidente.
- Citar a regulação brasileira do rodapé: a RO-CB.BR.01 do ONS, com os controles mínimos do Ambiente Regulado Cibernético, e a REN 964/2021 da ANEEL.

Transição: "e como se protege uma rede em que não dá para atualizar nada? Mudando a arquitetura."

## 27 Modelo Purdue, zonas e condutos (IEC 62443)

Arthur · ~2 min

"A norma de referência é a IEC 62443, organizada por papel: o operador do ativo, o integrador e o fabricante do produto. A parte 3-2 traz o conceito central: dividir a planta em **zonas**, que são conjuntos de ativos com o mesmo requisito de segurança, ligadas por **condutos**, que são os únicos caminhos autorizados e inspecionados entre elas."

"O mapa que se usa para isso é o modelo Purdue, do nível 5, a rede corporativa, até o nível 0, o processo físico. E a parte 3-3 define quatro níveis de segurança, do SL 1, que protege contra uma violação accidental, até o SL 4, que é o nível de um Estado-nação. O detalhe importante: o nível de segurança é definido **por zona**, não para a planta inteira."

### INTERAÇÃO — MODELO PURDUE

- O slide já abre no **nível 3,5, a DMZ industrial**. Explicar que ela é o único ponto de contato entre TI e TO, e que quase todo incidente grave passa por ali — pela regra temporária de firewall que virou permanente.
- Perguntar: *"por que não isolar totalmente a rede industrial da internet?"* Porque o negócio precisa do dado de produção, da manutenção remota e do fornecedor. Isolamento total não é opção; conduto controlado é.
- Descer até o nível 0 mostrando que o impacto muda de natureza: no 5 é phishing, no 3 é a estação de engenharia (caminho do Stuxnet), no 1 está o SIS e no 0 é vazamento, incêndio, gente ferida.
- Fechar no rodapé: o **SL não é da planta inteira**, é definido por zona. É normal conviver SL 2 no escritório e SL 3 na zona do SIS.

## 28 Notícias e tendências

Gabriela · ~3 min

"Três notícias. Em julho de 2025, criminosos usaram credenciais de um funcionário da C&M Software, empresa que conecta instituições financeiras menores aos sistemas do Banco Central, para desviar dinheiro de contas reserva via PIX. Segundo a imprensa, foram centenas de milhões de reais."

"Em setembro de 2025, o worm Shai-Hulud infectou pacotes do npm: roubava tokens de desenvolvedores e usava esses tokens para infectar outros pacotes. E em agosto de 2025 começaram a valer as regras do AI Act para modelos de propósito geral."

### INTERAÇÃO — DEBATE

- Perguntar: *"nos dois primeiros casos o invasor usou um acesso legítimo. Que controle do Bloco 1 teria ajudado? E quem responde ao regulador?"*
- Menor privilégio, detecção de comportamento anômalo, segregação de funções. Pela Res. 4.893, a instituição continua responsável mesmo terceirizando.
- **Antes da apresentação:** trocar ou complementar com uma notícia da semana.

## 29 Evolução do tema em 3 artigos

Diego · ~4 min

"Três artigos mostram como a área evoluiu. Em 2011, Hutchins, Cloppert e Amin, da Lockheed Martin, propuseram a Cyber Kill Chain: pensar a defesa a partir do adversário, em sete fases, e não só das vulnerabilidades."

"Em 2020, o NIST publicou a SP 800-207, que formalizou o Zero Trust: o perímetro de rede deixa de ser a fronteira de confiança. E em 2023, Greshake e colegas demonstraram a injeção indireta de prompt em aplicações reais com LLM: qualquer conteúdo que o modelo lê vira superfície de ataque."

"O fio condutor: a cada década, o que precisa ser defendido fica mais difuso — da rede para a identidade e, agora, para o contexto de um modelo."

### INTERAÇÃO

- Perguntar: *"como vocês acham que será o artigo marcante de 2030?"* (agentes autônomos, deepfakes, segurança de infraestrutura crítica...)

## Questões — Vinícius conduz; cada um resolve a do seu bloco

**Para todas as questões:** ler o enunciado em voz alta → apertar **T** (ou "Iniciar") → a turma vota → clicar na alternativa mais votada → "Revelar resposta" → explicar os passos que aparecem. Tempos sugeridos: 2 min nas de múltipla escolha, 1,5 min nas de Certo/Errado (ajustar no controle deslizante).

### 30 Como vai funcionar

Vinícius · ~1 min

"Agora é com vocês. São seis questões. Quatro são oficiais, com gabarito oficial: duas do ENADE 2021 e duas de concursos do Cebraspe. As outras duas foram elaboradas por nós, no formato das bancas, porque não encontramos questão oficial sobre os temas: uma sobre Zero Trust, baseada na NIST SP 800-207, e a bônus sobre regulação de IA. Cada uma tem um tempo no cronômetro, e depois resolvemos juntos."

- Se forem usar duas equipes, dividir a sala agora e anotar o placar no quadro.

### 31 Questão 1 · ENADE 2021, Q24 (criptografia)

Arthur resolve · ~3 min

#### RESOLUÇÃO FALADA

"A afirmação I está correta: quem assina usa a chave privada, e qualquer um verifica com a chave pública do remetente. Isso garante autenticidade."

"A II também: usar um vetor de inicialização diferente em cada mensagem faz com que textos iguais gerem cifras diferentes e dificulta repetir mensagens antigas."

"A III está errada: o AES é simétrico e usa a mesma chave dos dois lados. "Par de chaves" é da criptografia assimétrica."

"A IV está correta: o SHA-256 gera um hash, e comparar os hashes detecta alteração, ou seja, integridade. Gabarito oficial: letra E — I, II e IV."

- Relacionar com o slide 4: a questão cobre autenticidade, confidencialidade e integridade de uma vez.

### 32 Questão 2 · Zero Trust e defesa em profundidade (autoral)

Vinicius resolve · ~3 min

"Esta questão foi elaborada por nós, no formato Certo/Errado do Cebraspe, a partir da NIST SP 800-207. Ela cobre os slides 6 e 7."

"O item 1 está **errado**: os papéis estão trocados. Quem decide é o Policy Engine; o Policy Administrator executa a decisão e comanda o Policy Enforcement Point, que abre e fecha a conexão. A regra para memorizar é: **PE decide, PA executa, PEP conecta**."

"O item 2 também está **errado**, e é a pegadinha conceitual mais comum: Zero Trust não substitui a segmentação. A microssegmentação é justamente um dos modelos de implantação da própria SP 800-207, e a decisão de acesso olha identidade, dispositivo, recurso e contexto — não só o usuário. Defesa em profundidade continua valendo."

"O item 3 está **certo**: a confiança não é permanente, ela é reavaliada durante a sessão e pode ser revogada quando o contexto muda. Foi exatamente isso que faltou no Colonial Pipeline, em que a VPN dava confiança permanente a quem entrasse."

- Dica de prova: itens com palavras absolutas — "exclusivamente", "dispensável", "sempre" — costumam estar errados.

### 33 Questão 3 · Cebraspe EMBRAPA, itens 69 e 70 (ISO)

Gabriela resolve · ~2,5 min

"O item 69 está certo: é o controle 5.3 da 27002, segregação de funções. Quem pede não aprova, quem desenvolve não publica."

"O item 70 está errado. Controlar mudanças planejadas e rever as não intencionais fica na cláusula 8, Operação, e o planejamento de mudanças do SGSI na 6.3. A cláusula 5, Liderança, trata de política, papéis e comprometimento da direção. Gabarito oficial: 69 Certo, 70 Errado."

- Dica de prova: no Cebraspe um item errado anula um certo; em caso de dúvida, deixar em branco pode ser estratégia.

### 34 Questão 4 · ENADE 2021, Q12 (LGPD)

Diego resolve · ~3 min

"A afirmação I está correta: dados sensíveis, como origem racial, religião e opinião política, têm tratamento restrito pelo artigo 11."

"A II está errada: se a anonimização pode ser revertida com esforço razoável, o dado volta a ser pessoal, pelo artigo 12."

"A III está correta: são os direitos de confirmação, acesso, correção e eliminação do artigo 18, que vimos no slide 18."

"A IV está errada num detalhe: a ANPD fiscaliza e regulamenta, mas não modifica a lei; isso é papel do Congresso. Gabarito oficial: B — I e III."

### 35 Questão 5 · Cebraspe PCDF e ANM

Vinícius resolve · ~3 min

"O item 105 está errado. A justificativa oficial do Cebraspe diz que o certificado SSL só protege o transporte; ele não impede que você entregue sua senha a um site falso. Site com cadeado pode ser golpe."

"O item 108 está certo: o endereço IP é dado pessoal, precisa de base legal, e o titular tem direito a acesso e eliminação."

"O item 80 está errado: "garante blindagem" é absoluto demais. O SMS pode ser interceptado por SIM swap ou por phishing em tempo real — por isso falamos em FIDO2 no slide 5. Gabarito oficial: 105 Errado, 108 Certo, 80 Errado."

- Dica de prova: palavras absolutas como "garante", "elimina", "sempre" e "isenta" costumam indicar item errado no Cebraspe.

### 36 Bônus · Regulação de IA

Vinícius · ~2 min

"Esta questão foi elaborada por nós, no formato do ENADE. Um sistema que ranqueia currículos está no Anexo III do AI Act, na área de emprego, então é alto risco, com gestão de riscos, governança de dados, logs, supervisão humana e avaliação de conformidade. Resposta: B."

"O distrator é a E: ter um humano na decisão final não tira o sistema do regulamento. O PL 2338 também classifica seleção de pessoal como alto risco."

- [Mostrar o placar final das equipes.](#)

## Encerramento — todos

### 37 Síntese dos 4 pilares

Arthur conduz, todos falam · ~1,5 min

"Para fechar: os quatro pilares falam a mesma língua, a da gestão de riscos. Segurança protege o dado, governança prova que protege, privacidade garante que o uso é legítimo — e a IA exige tudo isso ao mesmo tempo."

#### INTERAÇÃO

- **Arthur** **clica no centro "Risco"**. Depois cada integrante **clica no seu pilar e diz uma frase**:
- **Arthur (Segurança)**: "CIA, menor privilégio e Zero Trust são o como proteger."
- **Gabriela (Governança)**: "ISO e NIST transformam controles soltos em programa com evidência."
- **Diego (Privacidade)**: "Proteger não basta: precisa ter base legal e respeitar os direitos do titular."
- **Vinícius (IA)**: "Na IA, dado vira instrução — por isso regulamos por risco e limitamos o impacto."
- **Clicar em uma ou duas interseções, por exemplo S n P (art. 46 da LGPD)**.

### 38 Checklist prático

Gabriela · ~1,5 min

"Se vocês forem levar algo para a empresa onde trabalham ou estagiam, é este checklist: governança, técnica, privacidade e IA."

- Perguntar: "*quantos desses itens a empresa de vocês já cumpre?*"
- **Marcar os itens que a turma disser que as empresas cumprem e comentar o resultado da barra.**
- Ponte: "vamos ver o que acontece quando parte disso falta."

### 39 Mesa de Crise (atividade interativa final)

Vinícius narra · Diego conduz a votação e clica · ~6 min

“(Vinícius) Agora vocês são o comitê de crise da PagFácil, uma fintech com 2 milhões de clientes, regulada pelo Banco Central. É sexta-feira, 23h47. São quatro rodadas; em cada uma vocês escolhem uma ação e ganham até 10 pontos. Um aviso: nenhuma das opções é absurda. Todas são coisas que empresas de verdade fazem — a diferença está na ordem e no motivo.”

#### ROTEIRO DAS RODADAS

- **Avisar a turma:** nenhuma alternativa é absurda. Todas soam profissionais — a diferença está na ordem das ações e no fundamento de cada uma. Por isso vale discutir antes de votar.
- **Rodada 1 · Detecção e contenção:** criptografia em massa e nota de resgate. Melhor: B — isolar em rede sem desligar os hosts e coletar memória e logs antes de remediar. Parciais (5): A, desligar (destrói a memória volátil) e D, acionar seguradora e forense antes de qualquer ação técnica (isso corre em paralelo, não no lugar da contenção). Zero: C, restaurar já — recuperar antes de erradicar.
- **Rodada 2 · Escopo e relógio regulatório:** VPN de ex-funcionário sem MFA, ~400 mil registros e discos com criptografia em repouso. Melhor: B — ANPD e titulares em 3 dias úteis do conhecimento, em caráter preliminar, mais Banco Central e ocorrência policial. Parciais (5): A, só o BC agora, e D, avisar a ANPD mas adiar os titulares. Zero: C, a pegadinha da criptografia em repouso — ela não protege nada quando o invasor age com credencial válida, por dentro da aplicação.
- **Rodada 3 · Erradicação e recuperação:** backups online criptografados, cópia imutável de 2 dias atrás, pressão para voltar hoje. Melhor: A — erradicar a persistência, reconstruir limpo, restaurar a cópia imutável e voltar gradualmente. Parciais (5): B, restaurar e "passar antivírus", e C, priorizar pelo BIA sem erradicar antes. Zero: D, negociar o decryptor pelas 48 h que faltam.
- **Rodada 4 · Prestação de contas:** ANPD abriu fiscalização e a diretoria quer encerrar. Melhor: B — revisão sem culpados, causa raiz documentada, plano com dono e prazo, métricas e atualização dos playbooks. Parciais (5): A, comprar a ferramenta, e C, mandar o relatório e arquivar. Zero: D, atribuir a causa ao analista de plantão.
- **Diego:** dar cerca de 1 minuto de discussão, contar os votos, clicar na opção vencedora e ler a explicação. Não revelar a melhor resposta antes do voto.
- No final, comentar a pontuação e ligar cada rodada ao que foi visto: NIST SP 800-61, LGPD/Res. 15, Res. 4.893, backups 3-2-1-1-0 e o caso Colonial Pipeline.

### 40 Referências

Qualquer integrante · ~1 min

“Antes de abrir para perguntas: todas as afirmações desta apresentação têm fonte. Estão reunidas aqui em quatro grupos — normas e frameworks, legislação e regulação, artigos e publicações técnicas, e os casos e as fontes das questões.”

- Slide de consulta: não precisa ser lido. Basta apontar os grupos e deixá-lo no ar por alguns segundos.
- Se o professor pedir, destacar as três referências que sustentam o fio condutor dos artigos (Kill Chain 2011, Zero Trust 2020, injeção indireta 2023) e as duas normas certificáveis (ISO 27001 e ISO 42001).

## 41 Perguntas e respostas

Todos (Arthur abre e fecha) · ~3 min

“(Arthur) Muito obrigado pela atenção e pela participação. Segurança é um processo contínuo de gestão de riscos — com pessoas, métodos, leis e, agora, modelos de IA no mesmo tabuleiro. Abrimos para perguntas.”

- Cada pergunta é respondida por quem apresentou o bloco relacionado.
- Se a turma estiver tímida, usar as perguntas de debate do slide: pagar resgate? Regulação de IA freia a inovação? DPO dentro da TI tem conflito de interesses?
- Arthur agradece ao professor e à turma e encerra.

## Perguntas que podem surgir

---

### Arthur

- **Zero Trust elimina a VPN?** Não necessariamente; a VPN deixa de ser a fronteira de confiança. Muitas empresas trocam por ZTNA, que dá acesso por aplicação, não à rede inteira.
- **Se a rede industrial é tão crítica, por que não isolá-la de vez?** Porque o negócio precisa do dado de produção, da manutenção remota do fabricante e do acesso de fornecedores. O "air gap" puro praticamente não existe mais — por isso a IEC 62443 trabalha com zonas e condutos controlados, e não com isolamento total.
- **Dá para aplicar Zero Trust em TO?** Em parte. Autenticação forte e microssegmentação sim; avaliação contínua com reautenticação no meio de uma operação crítica, não — em TO, interromper pode ser pior que o ataque.
- **Pagar o resgate é crime?** No Brasil não há proibição geral, mas pode violar sanções internacionais se o grupo estiver listado, e não garante a devolução dos dados.

### Gabriela

- **ISO 27001 ou NIST CSF: qual escolher?** Não são excludentes. O CSF serve para medir maturidade e priorizar; a ISO, para certificar. A 27002:2022 tem atributos que fazem o mapeamento entre os dois.
- **PCI DSS é lei?** Não, é contratual. Quem descumpre pode pagar multa às bandeiras ou perder o direito de aceitar cartões.
- **Quanto custa uma certificação ISO?** Depende do escopo; o maior custo costuma ser a implantação do SGSI, não a auditoria.

### Diego

- **Posso usar legítimo interesse para marketing?** Em alguns casos, sim — para clientes existentes, com produtos parecidos e opção fácil de sair —, desde que o teste LIA esteja documentado.
- **Toda empresa precisa de DPO?** Em regra, sim. Agentes de pequeno porte podem ser dispensados (Res. 2/2022), mas precisam manter um canal de comunicação.
- **Dado pseudonimizado é anônimo?** Não. Se é possível reidentificar com uma informação guardada à parte, continua sendo dado pessoal.

### Vinícius

- **O AI Act vale para empresas brasileiras?** Sim, se colocarem sistemas no mercado europeu ou se os resultados forem usados na UE — efeito extraterritorial, como o GDPR.
- **Dá para resolver prompt injection de vez?** Até hoje não. As defesas reduzem a chance; o mais confiável é limitar o que o modelo consegue fazer (menor privilégio e aprovação humana).
- **Usar o ChatGPT no trabalho viola a LGPD?** Pode violar, se envolver dados pessoais de clientes sem base legal ou sem contrato adequado com o fornecedor. Por isso o checklist pede uma política de uso de IA generativa.

Fontes das questões oficiais: INEP — ENADE 2021, Ciência da Computação (Bacharelado), caderno de prova e gabarito definitivo (questões 12 e 24); Cebbraspe — EMBRAPA (edital 2024, aplicação 23/3/2025), PCDF (aplicação 12/1/2025) e ANM (aplicação 16/2/2025), cadernos e gabaritos oficiais definitivos. As questões 2 (Zero Trust) e bônus (regulação de IA) foram elaboradas pela equipe, no formato das bancas, a partir da NIST SP 800-207 e do Regulamento (UE) 2024/1689. A lista completa de referências está no slide 40.